KUPPINGERCOLE
www.KUPPINGERCOLE.com

KuppingerCole Vendor Report

by Martin Kuppinger | December 2012

MetricStream

Bridging the gap between Business GRC and IT GRC.

KuppingerCole Vendor Report MetricStream



by Martin Kuppinger | mk@kuppingercole.com | December 2012

Content

1. Management Summary....3
2. Highlights....4
3. Customer Challenges and Industry Status....5
   3.1 Organizational Requirements....7
   3.2 Industry Status....9
   3.3 Mapping of Challenges/Status....9
4. Vendor evaluation – the Product Portfolio....10
   4.1 Product portfolio....11
   4.2 Supported use cases....13
5. Vendor and Ecosystem....14
   5.1 Company....14
   5.2 Services....14
6. Rating....15
7. Summary and Recommendations....20

Related Research:

KuppingerCole Overview Report: A GRC Reference Architecture

October 5, 2010

KuppingerCole Scenario: Understanding IT Service and Security Management - 70173

August 2, 2011

KuppingerCole Advisory Note: The Open API Economy - 70352

December 16, 2011

1. Management Summary

MetricStream is a vendor in the GRC (Governance, Risk Management, Compliance) market. Within that market, MetricStream is positioned as an Enterprise GRC vendor with good support for IT GRC, providing solutions that cover business aspects as well as provide the technical integration to IT systems. This is in contrast to pure-play Business GRC solutions which only focus on manual controls and don't provide out-of-the-box integration with IT systems.

MetricStream provides a number of solutions for different GRC requirements. These include, amongst others, solutions for regulatory compliance, corporate governance, IT GRC, risk management, or sustainable environment. There are also many pre-configured products supporting issue management, regulatory reporting, change management, or compliance management in general. Besides this, there is support for a broad number of industries. The MetricStream Enterprise Compliance Platform is the underlying platform for all MetricStream solutions and in fact the Enterprise GRC tool provided by MetricStream.

In contrast to many other Enterprise GRC platforms and especially to pure-play Business GRC tools, MetricStream provides strong integration capabilities and a good support for IT GRC. These are, from the KuppingerCole perspective, mission critical to implement Enterprise GRC concepts because they are the foundation to add automated controls when needed – and only the right mix of manual and automated controls will deliver the results companies need in their GRC initiatives. From a technical perspective, MetricStream's Enterprise Compliance Platform appears to be a well-thought out, mature solution.

Overall MetricStream is, from a KuppingerCole perspective, among the leading-edge vendors in the Enterprise GRC market. We strongly recommend evaluating MetricStream's offerings especially with focus on a broad coverage of pre-configured solutions and products for specific GRC requirements and the technical integration capabilities with lower level GRC and IT tools which may be in place.

2. Highlights

- Strong platform for complete Enterprise GRC, bridging the gap between Business GRC and IT GRC.
- Large number of pre-defined solutions and products for specific GRC requirements.
- Strong community support via ComplianceOnline.com and strong customer base across several verticals.
- Good workflow and reporting capabilities.
- Well-thought security concept.
- Strong technical integration capabilities based on the Infolet concept.
- Support for offline and decentralized use.
- Integrations with CCM (Continuous Controls Monitoring) products and technology-focused IT GRC point solutions.
- Own professional services and consulting in all areas, but few formal partnerships with external consulting partners. However these partners are global companies.
- Few formal technology partnerships to underpin the Infolet approach through technical integrations.
- Ability to manage emerging risks from Cloud, Mobile, and Social apps, support for virtualized IT assets in the Cloud.

3. Customer Challenges and Industry Status

When looking at today's IT, it is driven by some major evolutions. Everything which is done in IT has to take these evolutions into account. However, this is not only about IT – it is about the overall organization. How do organizations act in the market? How do they engage with their customers? How do they engage with their employees? And as with every change, this is not only about changing the organizations themselves, but also about implementing a governance infrastructure that is ready to deal with these changes. Simply said: When organizations become more agile and open, GRC infrastructures have to become more agile and open as well.

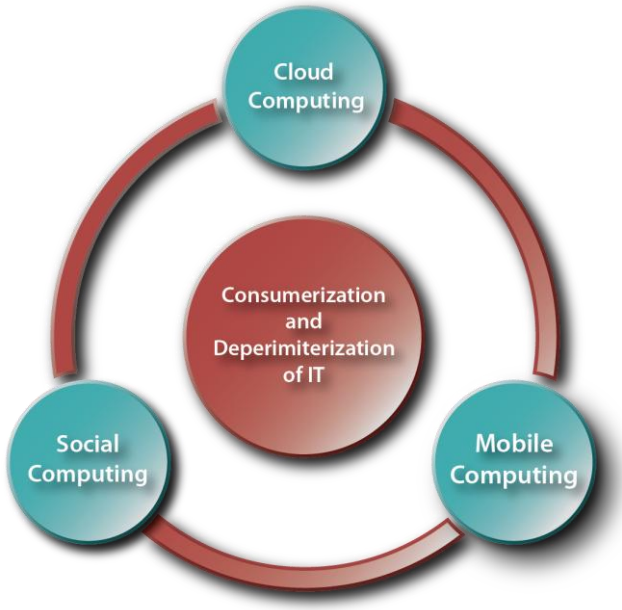


Fig. 1: The Evolutionary Areas of IT Influence

Figure 1 shows these areas. One is Social Computing, i.e. a tighter interaction between individuals and organizations based on sharing information in some way – between publicly available information and a directed, controlled flow of information.

The second evolution is Mobile Computing, allowing access to a broad range of services via the Internet from different devices. This also pushes the accessibility of services, given that an increasing number of persons have device and network access available at virtually any point of time.

The third evolution is Cloud Computing, which in this context isn't really new. It allows for using services which are located in the Internet to store and – willingly or unwillingly – share information with other parties.

All these trends affect IT fundamentally. The consumerization and deperimeterization of IT are logical consequences. Information technology (IT) is available to virtually everyone and virtually everywhere. It is not a business-to-business technology anymore, and hasn't been for quite a while. However, all three evolutions mentioned drive the consumerization of IT to a new level.

Deperimeterization is another logical consequence. Once formerly closed networks open up, there is no perimeter anymore. That not only affects the way Information Security has to be implemented, it also means that the borderlines between different organizations and between organizations and their counterparts in the form of individuals—customers, users, tenants, citizens, etc.—are no longer as clearly defined.

Having said this, there is obviously a massive impact on Identity, Security, and -last but not least - on GRC. There are more persons (and thus identities) to deal with, not to mention the "Internet of Things" adding masses of devices. But even without that "Internet of Things", there is an "Identity Explosion" organizations have to deal with. They have to look at more than their employees. The number of customers, leads, and prospects usually is far higher than the number of customers. Managing security becomes a far bigger challenge than ever before. Staying compliant becomes a far bigger challenge as well. Thus, these major evolutions massively affect what organizations have to do in all these areas.

In consequence, this also affects what companies have to do in the field of GRC (Governance, Risk Management, Compliance). Governance for an organization acting in an increasingly deperimeterized ecosystem and directly dealing with far more identities than ever before have to take into account (amongst other factors):

- more regulations when moving from local to global scale;
- more regulations due to increased customer participation and related privacy and eCommerce laws;
- increased agility requiring new approaches to govern the organization and its compliant state;
- increased complexity due to IT and data moving away from the premise;
- new types of devices, related security issues, and data sprawl in the days of Mobile Computing.

Simply said: An organization without an agile and mature GRC organization and supporting technology will not be able to deal with the changing environment – with the impact of the "Computing Troika": Social Computing, Mobile Computing, Cloud Computing.

3.1 Organizational Requirements

When looking at these evolutions in the context of GRC, there are some obvious challenges customers are facing. These are directly associated with organizational requirements, driven by the business. Some of the major challenges are:

- Becoming agile in GRC – with new regulations and new requirements due to a more global reach of the organization and due to new or changing business models (for example changes in eCommerce), organizations have to deal with more and changing regulations.
- Mobile Computing, Cloud Computing, and Social Computing all lead to new forms of communication and interaction. This involves information sprawl and new, specific regulations, for example around privacy. GRC environments have to be flexible enough to support this.
- Information technology is a business enabler – and business relies on information technology. In these days, IT and business can't be viewed in isolation. Thus Enterprise GRC in the sense of looking at all aspects of the enterprise – and not ignoring the IT part – is mandatory. It is about integrating all aspects of GRC, including IT GRC.
- Information Security is a bigger concern than ever, in an environment which is far more complex than ever before. GRC has to cover this.
- In a world with a quickly increasing number of relevant regulations, it is mandatory that organizations are able to quickly enhance their GRC approaches – by learning from best practices.
- The agility of business today requires automated approaches. Manual controls will always remain a part of GRC – but the more automated controls, the better.

Overall, the GRC landscape is changing fundamentally because organizations are acting in a different environment. They are opening up their business processes. They are using more external IT services. They have to deal with more users.

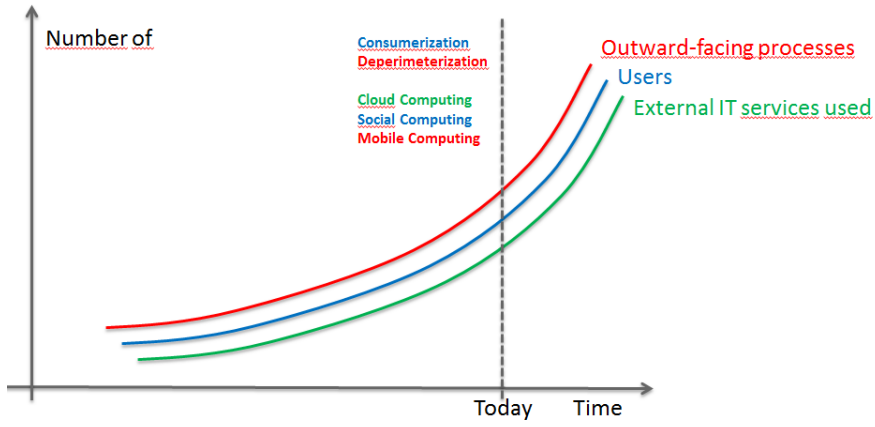


Fig. 2: Organizations are in a situation where they are confronted with exponential changes regarding outward-facing processes, users, and external IT services used.

The important aspect is: All these changes are exponential. And we are now in a situation where traditional organizational approaches and technologies are no longer sufficient to deal with these changes. We have to adopt everything: Organization, methods – including GRC approaches – and technology.

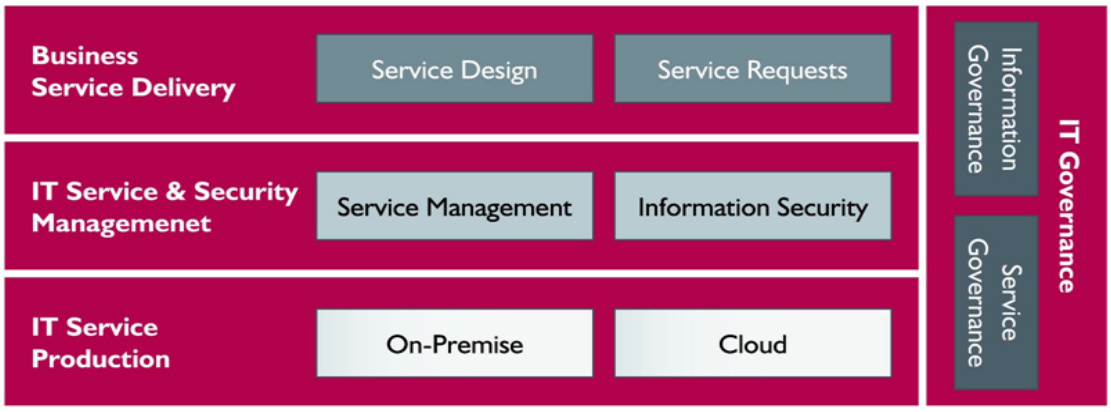


Fig. 3: The KuppingerCole IT Paradigm describes the to-be-state of IT.

The KuppingerCole IT Paradigm[1] describes a best-practice to-be state for the future IT organization which is ready to deal with these changes. From the IT perspective, GRC requirements are changing from technical system-oriented approaches towards Information Governance and Service Governance. These again are part of the overall Enterprise Governance approach shown in figure 4.

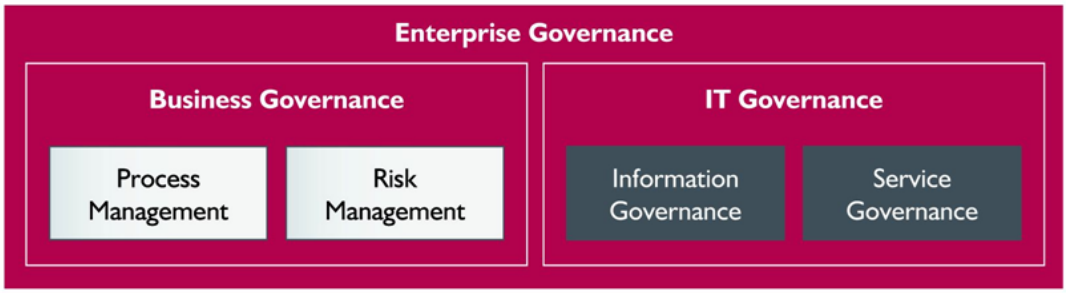


Fig. 4: The Role of Enterprise GRC in the context of the KuppingerCole IT Paradigm.

Organizations that want to be successful need an integrated approach on Enterprise Governance that allows them to cover all aspects in a standardized and integrated way. They have to understand that GRC is always done the same way, as described in the KuppingerCole GRC Reference Architecture[2]. Organizations have to change the way they act on GRC. And this requires the right solutions provided by the vendors – solutions, which are ready to deal with the challenges of the big changes described.

[1] http://www.kuppingercole.com/report/scenariofutreitorg70350130412
[2] http://www.kuppingercole.com/report/sp_overview_repo_grc_arch_051009

3.2 Industry Status

When looking at the industry and its offerings in the area of GRC we are observing a multi-faceted picture. There are different vendors with fundamentally different offerings. Some still sell what they frequently call Enterprise GRC but what in fact is only "Business GRC" - focusing on some aspects of the business but ignoring the tight and inseparable relationship to IT GRC. Some of these vendors have been acquired by IT vendors, which are driving the integration with IT and towards a real Enterprise GRC.

On the other side, there are some vendors which started as Enterprise GRC vendors from the beginning. However these are still few.

Below that level, there are many GRC point solutions as well, for specific industries like insurance companies or for specific areas of IT – like Access Governance or SIEM.

The overall perception is that Enterprise GRC vendors are on their way to supporting IT in these times of fundamental change. Business GRC vendors increasingly move towards a real Enterprise GRC with support for IT controls and integration with specific IT GRC solutions. It is however very important to carefully look at the offerings of vendors: Will the vendor's roadmap align with these evolutions? And are the current offerings mature enough to support your changing requirements?

3.3 Mapping of Challenges/Status

Overall we are in a situation where both customers and vendors increasingly pick up on these evolutions and adapt their strategies. Given that both sides are in a change process, there might be a mismatch. And as with every change, some will fail.

Customers, therefore, have to carefully evaluate whether the vendor provides what they need today and whether he is likely to provide what they will need in the future to optimally support their change process.

Vendors also have to pick up on these changes quickly to stay ahead of the customer requirements. As with every large evolution, some vendors are better at doing that than others. Every big change will bring new players into the market and drive some others out of it. That again means to customers that they have to carefully review the status and roadmap of their vendors of choice.

4. Vendor evaluation – the Product Portfolio

MetricStream is a vendor in the GRC (Governance, Risk Management, Compliance) market. Within that market, MetricStream is positioned as an Enterprise GRC vendor, providing solutions that cover business aspects as well as provide the technical integration to IT systems. This is in contrast to pure-play Business GRC solutions which only focus on manual controls and don't provide out-of-the-box integration with IT systems.

The KuppingerCole definition of GRC systems is as follows:

- Enterprise GRC: Holistic approaches which support all levels from C-level dashboards down to technical integrations with IT systems for providing data to automated controls. In fact these are typically Business GRC systems with a strong technical integration to "lower level" systems plus, sometimes, integrated technical controls.
- Business GRC: Pure-play solutions focused on the high-level dashboards and manual controls, with little or no capabilities for integration with technical GRC solutions and thus limited support for automated controls. Within Business GRC, there are also specific solutions focusing (only) on Operational Risk and other specific areas.
- Continuous Controls Monitoring: Solutions for the continuous monitoring of business-related controls to ensure proper execution of business by a close-to-real-time monitoring. In fact a specific form of Business GRC with tight integration into IT systems.
- IT GRC: Solutions for IT GRC like Access Governance, some of the SIEM (Security Information and Event Management) solutions, IT Service Management, and others. However, most of the tools available today in these segments don't really fit into IT GRC given their lack of support for a GRC methodology including defined policies and controls.
- Supporting technologies: Technologies that provide information out of systems to support the requirements of the higher-level GRC solutions and which might help to enforce policies.

From the KuppingerCole perspective, integration capabilities, the support for manual as automated controls, and the ability to span all layers of GRC requirements, e.g. providing details if required and allowing for drill-down, are mandatory for successful GRC deployments. GRC can't be limited to point solutions but has to become integrated across the entire organization, given that regulations, policies, and related controls frequently affect different parts of the organization.

4.1 Product portfolio

MetricStream provides a number of solutions for different GRC requirements. These include, among others, solutions for regulatory compliance, corporate governance, IT GRC, risk management, or sustainable environment. On the other hand there are many pre-configured products supporting issue management, regulatory reporting, change management, or compliance management in general. Besides this, there is support for a broad number of industries.

The MetricStream portfolio looks pretty complex at first glance. However, in reality it is based on a common platform and different pre-configurations of that platform to support the specific requirements. The MetricStream GRC Platform is the underlying platform for all MetricStream solutions and in fact the Enterprise GRC tool provided by MetricStream. However, MetricStream provides solutions for a quick start based on that platform.

The "content", e.g. specific configurations for different use cases, is supported by a large community of practitioners via ComplianceOnline.com, a portal founded by MetricStream some years ago. Based on that portal and a large number of customer projects, MetricStream is able to provide standard solutions for different use cases, solution areas, and industries.

MetricStream thus can offer

- Roles: The roles within an organization which are involved in GRC and supported by MetricStream.
- Applications: Specific applications for functional aspects of GRC, from Risk Management to Document Management and many others.
- Solutions: These cover specific regulations and requirements, ranging from SOX compliance to Operational Risk Management or Regulatory Intelligence.

This results in support for a large number of industries, based on the roles, applications, solutions, and best practices implemented therein.

As mentioned above, MetricStream is – from a technical point-of-view – a single-product company. However, the solution has various layers which allow for flexible use and customization. From the customer perspective, it thus provides a large number of different products and solutions. The specific appeal of that approach is that customers can have a quick-start with a specific GRC solution and add other capabilities over time, while still relying on the same technical infrastructure. This combination of solutions and a common technical platform is, from the KuppingerCole perspective, a key requirement for Enterprise GRC solutions. The current version 6 is based on a J2EE architecture with a broad range of capabilities. It allows for defining policies, controls, and related descriptions in a standardized way. These are backed by an embedded workflow engine which supports the related processes. Workflows

are used to route information, to manage the relationship between records, and to assign tasks based on business rules and conditions.

The modeling is supported by a graphical process flow designer. This tool also supports the creation of forms without coding. Thus new solutions can be created relatively easily and standard solutions are easy to adopt, without changes in code. Supporting such types of customization is a key requirement to support the quick implementation of policies and controls without large, complex, and costly additional software development projects.

Another area of the product is reporting. The platform provides a built-in reporting engine for creating reports and executive dashboards. In addition it supports drill-downs to the underlying data. End users can build custom reports using a wizard.

However, from the KuppingerCole perspective, the most important feature of the platform and a key differentiator are the so called Infolets. These are adapters which connect to external systems and data sources to extract data and provide it to the MetricStream database. These Infolets are the foundation for integration with other systems and for the implementation of automated controls in addition to the manual controls which can be built based on the Process Flow Designer and the Workflow Engine.

The MetricStream Enterprise Compliance Platform has a strong security concept. It supports 21 CFR Part 11 compliance for electronic records and signatures (Title 21 CFR Part 11 of the Code of Federal Regulations deals with the Food and Drug Administration (FDA) guidelines on electronic records and electronic signatures in the United States) and a broad range of encryption and access control technologies. Thus, information in the platform itself can be secured in a fine grained fashion, depending on the specific requirements of the use case.

Other interesting features are the Application Briefcase and the Zaplets which both allow for offline and distributed use. This allows, for example, for offline audits and the eMail-based delivery of application data and forms.

In the current release 6, MetricStream has added several important features:

- The data model has been enhanced and became more flexible. It now includes the GRC foundation, a set of libraries for risks, controls, processes, policies, assets, organizations, regulations, and other GRC elements. These elements are configurable. The model allows for a rapid implementation of new regulations, new governance approaches, and for rapid adoption to changes.
- The user experience has been improved in the current version, including easier access to contextual information.
- The already strong model for security and access management has been further improved.

- The platform now also enables linking between GRC and business performance management, moving closer to fulfill the old promise of real business activity monitoring based on well-defined controls and added business performance information.

Overall, the MetricStream Enterprise Compliance Platform is a strong offering to build Enterprise and IT GRC solutions on top of, especially due to its integration capabilities. MetricStream has, in contrast to many other vendors in that market segment, understood the value and need for integration and for supporting automated controls right from the beginning.

Again, as mentioned above, there are a large number of products and solutions available built on top of this platform. Usually such products and solutions will need customization to meet the specific customer requirements. However, since they are based on a standardized platform it is significantly easier to do such customizations than with GRC approaches based on spreadsheets or other point solutions.

4.2 Supported use cases

With its platform for Enterprise GRC MetricStream can support a broad range of use cases. The core concept is being the central platform for defining, managing, and enforcing policies and controls, including the necessary dashboard and reporting capabilities. The standard products and solutions offered by MetricStream provide a good indication of the supported use cases – virtually the entire range of Enterprise GRC requirements. An overview of these products and solutions is available at http://www.metricstream.com/.

Notably, MetricStream supports IT GRC as a "control of controls" as well as the integration with CCM tools but isn't a complete IT Security solution (covering all specific requirements like Access Governance, SIEM, or Service Management) or IT Operations/Service Management solution by itself. It is the platform for supporting Business GRC requirements and integrating them with other IT Security and GRC point solutions for a complete Enterprise GRC approach. MetricStream provides good IT GRC support and can build the layer on top of other solutions.

5. Vendor and Ecosystem

MetricStream is a company that has been in the market for several years now. The company has a significant number of customers in many different industries.

5.1 Company

MetricStream is a privately held company which doesn't publish financial data. It has several well-known investors and appears to be solidly financed. With a global presence in all relevant regions, MetricStream shows significant presence in the market.

However, being a venture-financed company, MetricStream is likely to either become acquired at some point in time or to go public. As a potential acquisition target, there is some slight risk for the long-term execution of strategies.

5.2 Services

MetricStream provides professional services in all relevant areas, including implementation, validation, and hosting. MetricStream has office locations in various regions, including EMEA and APAC, and thus is able to support customers with local professional services. Besides this, MetricStream GRC Consulting & Advisory Services provide the business consulting required for implementing GRC programs.

In addition, tools like MetricStream are frequently supported and implemented by large business consultant organizations, thus sufficient support commonly is available for MetricStream-based projects.

However, a shortcoming from KuppingerCole perspective is the relatively small partner ecosystem. Enterprise GRC success relies not only on the proper definition and implementation of policies and controls but as well on the integration with the IT tool which support the automated controls. MetricStream has several integrations but few formalized partnerships. Putting more emphasis on that aspect and fully formalizing and maturing existing partnerships might be helpful to drive customer's confidence in the ability to execute when it comes to integrations. The good thing is that all MetricStream partners are global companies which can support MetricStream customers on a global scale.

Another important point to consider is that MetricStream has successfully managed to engage partners and customers in supporting best practice approaches to GRC which are implemented in the MetricStream solutions. That allows customers a quick start into GRC.

6. Rating

KuppingerCole as an analyst company regularly does evaluations of products and vendors. The results are, amongst other types of publications and services, published in the KuppingerCole Product Reports and KuppingerCole Vendor Reports. KuppingerCole uses a standardized rating to provide a quick overview on our perception of the products or vendors.

Providing a quick overview of the KuppingerCole rating of products requires an approach combining clarity, accuracy, and completeness of information at a glance. KuppingerCole uses the following categories to rate products:

- Security
- Functionality
- Integration
- Interoperability
- Usability

Security – security is measured by the degree of security within the product. Information Security is a key element and requirement in the KuppingerCole IT Model (#70129 Scenario Understanding IT Service and Security Management). Thus, providing a mature approach to security and having a well-defined internal security concept are key factors when evaluating products. Shortcomings such as having no or only a very coarse-grained, internal authorization concept are understood as weaknesses in security. Known security vulnerabilities and hacks are as well understood as weaknesses. The rating then is based on the severity of such issues and the way a vendor deals with them.

Functionality – this is measured in relation to three factors. One is what the vendor promises to deliver. The second is the status of the industry. The third factor is what KuppingerCole would expect the industry to deliver to meet the customer requirements. In mature market segments, the status of the industry and the KuppingerCole expectations usually are virtually the same. In emerging markets they might differ significantly, with no single vendor meeting the expectations of KuppingerCole, thus leading to relatively low ratings for all products in that market segment. Not providing what customers can expect on average from vendors in a market segment usually leads to a degradation of the rating, unless the product provides other features or uses another approach which appears to provide customer benefits.

Integration—integration is measured by the degree in which the vendor has integrated the individual technologies or products in the portfolio. Thus, when we use the term integration, we are referring to the extent in which products interoperate with themselves.

This detail can be uncovered by looking at what an administrator is required to do in the deployment, operation, management and discontinuation of the each product. The degree of integration is then directly related to how much overhead this process requires. For example: if each product maintains its own set of names and passwords for every person involved, it is not well integrated. And if products use different databases or different administration tools with inconsistent user interfaces, they are not well integrated.

On the other hand, if a single name and password can allow the admin to deal with all aspects of the product suite, then a better level of integration has been achieved.

Interoperability—interoperability also can have many meanings. We use the term "interoperability" to refer to the ability of a product to work with other vendors' products, standards, or technologies. In this context it means the degree in which the vendor has integrated the individual products or technologies with other products or standards that are important outside of the product family. Extensibility is part of this and measured by the degree in which a vendor allows its technologies and products to be extended for the purposes of its constituents. We think Extensibility is so important that it is given equal status so as to insure its importance and understanding by both the vendor and the customer. As we move forward, just providing good documentation is inadequate. We are moving to an era when acceptable extensibility will require programmatic access through a well-documented and secure set of APIs. Refer to the Open API Economy Document (#70352 Advisory Note: The Open API Economy) for more information about the nature and state of extensibility and interoperability.

Usability —accessibility refers to the degree in which the vendor enables the accessibility to its technologies and products to its constituencies. This typically addresses two aspects of usability – the end user view and the administrator view. Sometimes just good documentation can create adequate accessibility. However, overall we have strong expectations regarding well integrated user interfaces and a high degree of consistency across user interfaces of a product or different products of a vendor. We also expect vendors to follow common, established approaches to user interface design.

We focus on security, functionality, integration, interoperability, and usability for the following key reasons:

- Increased People Participation—Human participation in systems at any level is the highest area of cost and potential breakdown for any IT endeavor.
- Lack of Security, Functionality, Integration, Interoperability, and Usability—Lack of excellence in any of these areas will only result in increased human participation in deploying and maintaining IT systems.
- Increased Identity and Security Exposure to Failure—Increased People Participation and Lack of Security, Functionality, Integration, Interoperability, and Usability not only significantly increase costs, but inevitably lead to mistakes and breakdown. This will create openings for attack and failure.

Thus when Kuppinger Cole evaluates a set of technologies or products from a given vendor, the degree of product Security, Functionality, Integration, Interoperability, and Usability which the vendor has provided is of highest importance. This is because lack of excellence in any or all of these areas will lead to inevitable identity and security breakdowns and weak infrastructure. For MetricStream, the following ratings apply:

Security ↗	Overall a very strong offering with a broad set of security functionality. We are observing some deficiencies in the area of the externalization of security controls to other systems – overall the strong security concepts appears to be too much "self-contained". Despite this fact and based on the overall well thought out approach we decided for a positive rating anyhow.
Functionality ↗	MetricStream provides a broad set of functionality based on its core platform, with its different applications and solutions. The amount of "best practices built into the product" is impressive. We thus rate the product very positively from a functional perspective.
Integration ↗	MetricStream started with a core platform and added applications and solutions over time. Thus customers can build on a tightly integrated approach. This is, from our perspective, a clear competitive advantage of MetricStream given that all customer organizations will have to proceed towards a consistent, tightly integrated GRC strategy.
Interoperability ➔	MetricStream provides a defined concept for interoperability with other platforms, based on their Infolets. MetricStream thus has a robust integration architecture. Thus interoperability appears to be an option which is well supported by MetricStream. However, reality is that there is a need for greater out-of-the-box support for integration in complex heterogeneous landscapes and for different types of systems, from IT security to core business applications. Based on these aspects we opt for a still neutral (but close to positive) rating in this area.
Usability ↗	Given that MetricStream is based on a consistent architecture, the company doesn't have to deal with different user interfaces of different components. The user interface has been further improved in the current release, providing good functionality for the targeted user groups.

For KuppingerCole Vendor Reports, additional ratings are used as part of the vendor evaluation. The specific areas we rate for vendors are

- Innovativeness
- Market position
- Financial strength
- Ecosystem

Innovativeness – this is measured as the capability to drive innovation in a direction which aligns with the KuppingerCole understanding of the particular market segment(s) the vendor is in. Innovation has no value by itself but needs to provide clear benefits to the customer. However, being innovative is an important factor for trust in vendors, because innovative vendors are more likely to remain leading-edge. An important element of this dimension of the KuppingerCole ratings is the support of standardization initiatives if applicable. Driving innovation without standardization frequently leads to lock-in scenarios. Thus active participation in standardization initiatives adds to the positive rating of innovativeness.

Market position – measures the position the vendor has in the market or the relevant market segments. This is an average rating over all markets in which a vendor is active, e.g. being weak in one segment doesn't lead to a very low overall rating. This factor takes into account the vendor's presence in major markets.

Financial strength – even while KuppingerCole doesn't consider size to be a value by itself, financial strength is an important factor for customers when making decisions. In general, publicly available financial information is an important factor therein. Companies which are venture-financed are in general more likely to become an acquisition target, with massive risks for the execution of the vendor's roadmap.

Ecosystem – this dimension looks at the ecosystem of the vendor. It focuses mainly on the partner base of a vendor and the approach the vendor takes to act as a "good citizen" in heterogeneous IT environments.

For MetricStream, the following ratings apply:

Innovativeness ↗	Based on the approach MetricStream took for Enterprise and IT GRC we opt for a positive rating. However, MetricStream will need to confirm that rating over time especially in the area of interoperability.
Market position ↗	MetricStream is amongst the leading Enterprise and IT GRC vendors. Given the market entry of some large IT companies like IBM and RSA Security/EMC, this position might become challenged. However, as of now they are in a strong position.
Financial strength ➔	MetricStream as a privately held organization doesn't officially provide financial information. Based on the number of customers we opt anyhow for a neutral rating, even while customers should challenge MetricStream in that area before deciding for MetricStream offerings.
Ecosystem ➔	MetricStream has some large, global partners and an active community. However the company lacks a larger partner ecosystem.

7. Summary and Recommendations

Enterprise GRC as a concept is a key requirement for any organization. Having the organization in place to enforce policies and controls is mandatory to meet the requirements of regulatory compliance as well as good corporate governance. Enterprise GRC needs platforms which support different requirements and which are able to integrate with more technical GRC tools like CCM (Continuous Controls Monitoring) and technical IT GRC point solutions such as Access Governance or SIEM as well as with data sources providing information into these controls. They also need a strong support for IT GRC, beyond pure Business GRC. Relying on point solutions or spreadsheets isn't sufficient anymore to deal with the rising complexity of GRC requirements.

MetricStream's Enterprise GRC Platform is a standard environment for implementing Enterprise GRC, supported by a large number of pre-defined products and solutions which allow it to fulfill specific requirements based on best practices. In contrast to many other Enterprise GRC platforms and especially to pure-play Business GRC tools, MetricStream provides strong integration capabilities. These are, from the KuppingerCole perspective, mission critical for implementing Enterprise GRC concepts because they are the foundation to which you add automated controls when needed – and only the right mix of manual and automated controls will deliver the results companies need in their GRC initiatives.

From a technical perspective, MetricStream's Enterprise Compliance Platform appears to be a well thought out, mature solution. However we'd like to see significantly more fully formalized and matured partnerships and document integrations based on the Infolet concept of the platform, as well towards CCM and SIEM as towards Access Governance and other types of IT GRC solutions.

Overall MetricStream is, from a KuppingerCole perspective, among the leading-edge vendors in the Enterprise GRC and IT GRC market. We strongly recommend evaluating MetricStream's offerings especially with focus on a broad coverage of pre-configured solutions and products for specific GRC requirements and the technical integration capabilities with the lower level GRC and IT tools in place.

© 2012 Kuppinger Cole Ltd. All rights reserved. Reproduction and distribution of this publication in any form is forbidden unless prior written permission. KuppingerCole disclaim all warranties as to the adequacy, accuracy or to the completeness of information contained in this document. Even if KuppingerCole research documents may discuss legal issues related to information security and technology, KuppingerCole do not provide any legal services or advice and its publications shall not be used as such. KuppingerCole shall have no liability for errors or inadequacies in the information contained in this document. Any opinion expressed may be subject to change without notice.

KUPPINGERCOLE
www.KUPPINGERCOLE.com

The Future of Information Security – Today.

KuppingerCole supports IT professionals with outstanding expertise in defining IT strategies and in relevant decision making processes. As a leading analyst company **KuppingerCole** provides first-hand vendor-neutral information. Our services allow you to feel comfortable and secure in taking decisions essential to your business.

Kuppinger Cole Ltd.

Headquarters
Am Schloßpark 129
D-65203 Wiesbaden | Germany

Phone +49 (211) 23 70 77 - 0
Fax +49 (211) 23 70 77 - 11

www.kuppingercole.com

KuppingerCole, founded in 2004, is a leading Europe-based analyst company for identity focused information security, both in classical and in cloud environments. **KuppingerCole** stands for expertise, thought leadership, and a vendor-neutral view on these information security market segments, covering all relevant aspects like Identity and Access Management (IAM), Governance, Risk Management and Compliance (GRC), IT Risk Management, Authentication and Authorization, Single Sign-On, Federation, User Centric Identity Management, eID cards, Cloud Security and Management, and Virtualization.

For further information, please contact **clients@kuppingercole.com**